OWASP (Open Worldwide Application Security Project) is a group who provides a list of the top ten security risks to web applications. For this assignment, we will be using the OWASP Top 10 from 2021 (*OWASP Top 10:2021*, n.d.). We need to start by agreeing on definitions. Let's go through each of the top ten and discuss them. The top ten in order are:

1. Broken Access Control
2. Cryptographic Failures
3. Injection
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable and Outdated Components
7. Identification and Authentication Failures
8. Software and Data Integrity Failures
9. Security Logging and Monitoring Failures
10. Server-Side Request Forgery (SSRF)

We will begin with number ten. Server-Side Request Forgery or SSRF. SSRF is a vulnerability that allows an attacker to make an application make requests to the wrong location. This could allow an attacker to force the application to connect to external systems. This connection could leak sensitive data. SSRFs often lead to the attacker getting data or even the ability to execute commands.

Security Logging and Monitoring Failures happen when the events are not being recorded by the security; when a system does not track logins, failed logins or transactions. Warnings and errors don't generate clear log messages. Logs are stored locally. All of these are parts of Security Logging and Monitoring Failures.

Software and Data Integrity Failures are vulnerabilities caused by an application relying on plugins or libraries that are from untrusted sources. Another cause of these vulnerabilities are applications that auto-update without proper security checks

Identification and Authentication Failures all revolve around failure to keep the user's identity, authentication, and session management secure. An application may permit weak passwords, such as password, or store passwords in plain text without encryption. The application may expose session identifiers in the URL or may reuse old session identifiers.

Vulnerable and Outdated Components is a concern if the application uses vulnerable or out of date software. It is also a concern when the developers don't regularly scan for vulnerabilities or test the compatibility of updated, upgraded, or patched libraries.

Security Misconfiguration can occur when default accounts and their passwords are still enabled and unchanged. Unnecessary features are enabled, or upgraded systems don't have the latest security activated. A server does not send security headers or directives or out-of-date software.

Insecure Design is defined as “missing or ineffective control design.” (A04 Insecure Design - OWASP Top 10:2021, n.d.). An insecure design cannot be fixed by perfect security implementation as the security controls needed were never created. One factor of insecure design is failure to determine what level of security is needed for an application.

Injection is a threat when user supplied data is not validated, filtered or sanitized before use. Some of the most common Injections are SQL, NoSQL, Object Relational Mapping (ORM), LDAP, and Expression Language (EL) or Object Graph Navigation Library (OGNL) injection. All are the same, hostile data is used to extract information that shouldn't normally be accessible.

Cryptographic Failures are caused when data is at any point not encrypted. If data is transmitted in plain text, it is a Cryptographic Failure. Are crypto keys being reused? Or are old algorithms being used? Are old hash functions being used? All of these are Cryptographic Failures.

Finally, number one. The largest threat of 2021, Broken Access Control. Broken Access Control allows users to operate outside their permissions. Examples include bypassing control checks by tampering with the URL. Escalation of access or being able to act as an admin while only being logged in as a user. Viewing or editing someone else's account.

Hackazon stores many different forms of valuable information due to it being an online store front. It stores user profiles and everything that goes along with it. This includes passwords and emails, payment information and anything else tied to a user's profile. A user's home address may be kept for future orders. Hackazon also stores all the sellers' information. This would include the product information, as well as shipping address and possibly seller payment information. Hackazon would also store data that the users don't see. Session tokens, server infrastructure and admin accounts. Who is using Hackazon? Obliviously there are the customers. The people on Hackazon that order something. There are also retailers who have accounts to maintain their storefront. Other risers would be the Hackazon staff, the support and admin users who keep the site running. On the other side there may be people trying to access Hackazon that shouldn't be allowed to. For example, external attackers. These people are trying to break into the

site to acquire sensitive data for themselves. You may also find bots on Hackazon. Automated tools that buy large quantities of an item to be sold at a higher price. Now Hackazon is a legitimate site. They don't want their systems to be hacked. They have security goals. They want all the data to be confidential. They built their servers to resist DDOS attacks, so the site is always available. They want to be a secure site that consumers can trust to keep their information safe.

Now that we know what Hackazon is protecting we need to perform a risk analysis. For this risk analysis we will be using OWASP Risk Rating Methodology. Using the OWASP method we will look at several different aspects of the threat. We use the formula, *likelihood X impact* to determine the risk. Below are the likelihood table (fig 1.1) and the impact table (fig 1.2).

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection

Fig 1.1

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation

Fig 1.2

We are going to use these tables to determine the overall risk each of the OWASP top ten poses to Hackazon.

1. Broken Access Control

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
1	9	9	8	7	5	6	3

Likelihood = 6

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
7	3	1	5	1	3	5	5

Impact = 3.75

Overall risk severity = Medium

Broken access control does not require much skill on the part of the attacker and is relatively easy to recognize as the users are able to do things outside their normal ability. The overall impact on availability and the business as a whole is lower than other threats.

2. Cryptographic Failures

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
5	9	4	9	3	3	4	3

Likelihood = 5

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
9	1	1	7	1	4	5	7

Impact = 4.3

Overall risk severity = Medium

Cryptographic failures can be extremely valuable to hackers. They may be able to get payment information. However, it isn't necessarily easy to find places where these failures exist, and it requires some level of skill to exploit the vulnerability. The impact of these failures is large scale loss of trust and loss of confidentiality. Though the service as a whole is unaffected.

3. Injection

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
5	9	4	9	7	3	4	1

Likelihood = 5.25

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
7	3	5	7	3	4	5	5

Impact = 4.875

Overall risk severity = Medium

Injection has a large impact on the confidentiality and integrity of data on a website. However, it requires some skill and knowledge of Injection to take advantage of the vulnerability.

4. Insecure Design

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
6	4	7	6	7	3	1	9

Likelihood = 5.375

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
5	3	1	1	1	1	5	5

Impact = 2.75

Overall risk severity = Low

The threat of insecure design is more on the development side. Proper security was not baked into the system when it was being made.

5. Security Misconfiguration

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
9	4	7	2	3	3	4	3

Likelihood = 4.375

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
4	1	1	7	1	2	2	3

Impact = 2.625

Overall risk severity = Low

While security misconfiguration is a problem, the system still has security active. This means it takes skill and knowledge to take advantage of the misconfiguration.

6. Vulnerable and Outdated Components

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
5	4	6	7	3	5	6	3

Likelihood = 4.875

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation

4	1	1	7	1	2	2	3

Impact = 2.625

Overall risk severity = Low

Vulnerable and outdated components don't have much impact on the data or business. But many times, these older exploits are more well known. The overall risk is low.

7. Identification and Authentication Failures

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
3	9	7	9	4	4	4	3

Likelihood = 5.375

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
6	3	3	7	3	4	4	5

Impact = 4.375

Overall risk severity = Medium

Authentication failures require a higher level of skill to fully exploit. However, anyone can take advantage of the failure. The impact is possible loss of data.

8. Software and Data Integrity Failures

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
6	4	4	2	1	1	4	9

Likelihood = 3.875

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
6	4	7	1	3	3	5	5

Impact = 4.25

Overall risk severity = Medium

Many times, software is designed partly by using libraries from external sources. It is possible for those libraries to be augmented with a virus or backdoor. With many systems auto-updating it is a specific but possible threat.

9. Security Logging and Monitoring Failures

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
9	9	4	2	3	3	4	9

Likelihood = 5.375

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation

6	5	3	7	3	1	2	4

Impact = 3.875

Overall risk severity = Medium

Security logging and monitoring failures require a high level of security knowledge to exploit. However, there is a good chance it won't be logged by the security system.

10. Server-Side Request Forgery (SSRF)

Skill level	Motive	Opportunity	Size	Ease of discovery	Ease of exploit	Awareness	Intrusion detection
4	1	6	9	5	5	4	8

Likelihood = 5.25

Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability	Financial damage	Reputation damage	Non-compliance	Privacy violation
2	2	1	7	1	1	1	3

Impact = 2.25

Overall risk severity = Low

SSRFs are a threat but not nearly as much as the other nine. It has a fairly low impact on the website.

References

OWASP Top 10:2021. (n.d.). https://owasp.org/Top10/2021/

Secure Web development using OWASP Guidelines. (2021, May 6). IEEE Conference Publication | IEEE Xplore. https://ieeexplore.ieee.org/abstract/document/9432179

Bach-Nutman, M. (2020, December 17). Understanding the top 10 OWASP vulnerabilities. arXiv.org. https://arxiv.org/abs/2012.09960

S, K. B., Sridhar, V., & R, S. K. (2019). A CASE STUDY: RISK RATING METHODOLOGY FOR E-GOVERNANCE APPLICATION SECURITY RISKS. *I-manager's Journal on Software Engineering*, *13*(3), 39. https://doi.org/10.26634/jse.13.3.15546

Merkow, M. S., & Raghavan, L. (2012b). Secure and resilient software development. In Auerbach Publications eBooks. https://doi.org/10.1201/ebk1439826966

OWASP Risk Rating Methodology | OWASP Foundation. (n.d.). https://owasp.org/www-community/OWASP_Risk_Rating_Methodology